

Curais Security Assessment (Initial)

Scope and current posture

This assessment covers the current SnapAid codebase and the planned Curais expansion. SnapAid currently sends user-entered symptom text to a third-party AI API, keeps results in browser session storage, and provides emergency guidance. It does not currently implement accounts or persistent patient records.

Current strengths

- AI key is server-side, not shipped to the browser.
- Input length is limited and the guidance response is schema-normalized.
- API requests have in-memory IP rate limiting.
- Curated emergency paths avoid an AI request.

Priority findings

Priority	Finding	Required action
P0	AI content can be unsafe or misleading despite structured output.	Add clinical-review governance, high-risk keyword routing to curated emergency content, output safety checks, and user reporting before a public Curais launch.
P0	Health information is transmitted to a third-party model provider.	Publish a clear privacy notice; minimize/strip identifiers; verify provider data-retention, regional processing, and no-training terms; obtain explicit consent before record saving.
P1	Current in-memory rate limiter does not work reliably across serverless instances.	Move to a shared, durable rate-limit store with bot/abuse monitoring.
P1	No authentication/authorization model exists for future records.	Implement scoped RBAC/ABAC, patient sharing grants, MFA for clinicians, and audit logs before storing PHI/health records.
P1	No formal security headers/CSP are visible in the current app configuration.	Add CSP, HSTS, frame protections, secure cookies, dependency scanning, and production error redaction.
P2	sessionStorage keeps guidance on the device until the browser session ends.	Explain this behavior; use encrypted server storage only after opt-in and provide delete/export controls.

Required controls before R2

- Threat model and data-flow review for every health-data feature.
- Encryption in transit and at rest; managed keys and rotation policy.

- Separate production environments, secret manager, least-privilege service roles, and access review.
- Tamper-evident audit events for record access, changes, shares, exports, and admin actions.
- Incident response playbook, backups/restore test, vulnerability scanning, and penetration test.
- Legal/privacy review for Indian health-data obligations and every target market. This document is not legal advice.